

OWASP ZAP

Aim

To use OWASP ZAP for web application testing to identify SQL Injection and Cross-Site Scripting (XSS) vulnerabilities.

Algorithm

1. Start Windows and launch OWASP ZAP.
2. Open Quick Start → Automated Scan.
3. Enter the target URL: <http://testfire.net>
4. Start the scan and allow ZAP to crawl the application.
5. Open the Alerts tab after the scan.
6. Check for SQL Injection and XSS vulnerabilities.
7. Record the risk level, affected URL, parameter, and evidence.
8. Take screenshots of the relevant alerts.
9. Stop the scan and close OWASP ZAP.

output

SQL injection

URL : http://testfire.net

Risk : High

Confidence : Medium

Parameter : uid

Attack : ZAP OR 1 = 1

Evidence

CWE ID : 89

WASC ID : 19

SOURCE : Active (40018 - SQL injection)

Cross site scripting

URL: http://testfire.net

Risk : high

Confidence : medium

Parameter : name

Attack : </p> <script>alert(1)

Evidence : </p> <script>

CWE ID : 79

WASC ID : 8

Source : Active